Lab11 NW Security Ethical Hacking2

Class:	M01
Student ID:	B2206003
Name:	Nguyễn Hồ Gia Phúc
Email address:	Phucb2206003@student.ctu.edu.vn
Submmitting date:	27/11/2025

Scenario

No	Steps	Remarks
1	Environment Setting	Target IP : test-bed address Target URL : test-bed URL
2	**Choose** Nikto installation type	
3	**Run the program**	
4	Analyze **the result based on your idea**	List up the vulnerability checking items Grade the vulnerability level

① Select one Nikto installation type and install it on your system for exercise

- Type1: **VM Ubuntu**

```
b2206003@b2206003-VirtualBox:~$ nikto --help
Unknown option: help

       -config+            Use this config file
       -Display+           Turn on/off display outputs
       -dbcheck            check database and other key files for syntax errors
       -Format+            save file (-o) format
       -Help               Extended help information
       -host+              target host
       -id+                Host authentication to use, format is id:pass or id:p
ass:realm
       -list-plugins       List all available plugins
       -output+            Write output to this file
       -nossl              Disables using SSL
       -no404              Disables 404 checks
       -Plugins+           List of plugins to run (default: ALL)
       -port+              Port to use (default 80)
       -root+              Prepend root value to all requests, format is /direct
ory
       -ssl                Force ssl mode on port
       -Tuning+            Scan tuning
       -timeout+           Timeout for requests (default 10 seconds)
       -update             Update databases and plugins from CIRT.net
       -Version            Print plugin and database versions
```

② Run Nikto

```
b2206003@b2206003-VirtualBox:~$ nikto -h google.com
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          142.250.71.238
+ Target Hostname:    google.com
+ Target Port:        80
+ Start Time:         2025-11-27 18:12:58 (GMT7)
---------------------------------------------------------------------------
+ Server: gws
+ Uncommon header 'content-security-policy-report-only' found, with contents: ob
ject-src 'none';base-uri 'self';script-src 'nonce-RtY6jMBEg8FAZBwVVpJ0AA' 'stric
t-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri
 https://csp.withgoogle.com/csp/gws/other-hp
+ Uncommon header 'x-frame-options' found, with contents: SAMEORIGIN
+ Uncommon header 'x-xss-protection' found, with contents: 0
+ Root page / redirects to: http://www.google.com/
+ Uncommon header 'referrer-policy' found, with contents: no-referrer
```

```
+ Uncommon header 'x-xss-protection' found, with contents: 0
+ Root page / redirects to: http://www.google.com/
+ Uncommon header 'referrer-policy' found, with contents: no-referrer
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server banner has changed from 'gws' to 'sffe' which may suggest a WAF, load b
alancer or proxy is in place
+ Uncommon header 'x-content-type-options' found, with contents: nosniff
+ Uncommon header 'cross-origin-resource-policy' found, with contents: cross-ori
gin
+ Cookie AEC created without the httponly flag
+ Cookie NID created without the httponly flag
+ Uncommon header 'content-security-policy' found, with contents: object-src 'no
ne';base-uri 'self';script-src 'nonce-Ci-jkdCDgDDXRbHNcRPIAA' 'strict-dynamic' '
report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp
.withgoogle.com/csp/gws/other
+ Uncommon header 'accept-ch' found, with contents: Sec-CH-UA-Arch, Sec-CH-UA-Bi
tness, Sec-CH-UA-Full-Version, Sec-CH-UA-Full-Version-List, Sec-CH-UA-Model, Sec
-CH-UA-WoW64, Sec-CH-UA-Form-Factors, Sec-CH-UA-Platform, Sec-CH-UA-Platform-Ver
sion
+ Uncommon header 'cross-origin-opener-policy' found, with contents: same-origin
+ Uncommon header 'permissions-policy' found, with contents: ch-ua-arch=*, ch-ua
-bitness=*, ch-ua-full-version=*, ch-ua-full-version-list=*, ch-ua-model=*, ch-u
a-wow64=*, ch-ua-form-factors=*, ch-ua-platform=*, ch-ua-platform-version=*
```

③ Anayze the result

During Lab 11 with Nikto, the exercise performed a target scan using the testbed's IP/URL. Nikto is a specialized tool used to detect common vulnerabilities on web servers, including misconfiguration, outdated server versions, sensitive files/paths, and platform security flaws.

After running the Nikto command, the program returns a list of vulnerability checking items. Here is a summary analysis:

4.1. Categories Identified by Nikto

In this report, Nikto conducted a series of security assessments, including:

● Web Server Version Check

Nikto compares the current server version against its vulnerability database to determine whether:
– The server is running a recent or outdated version
– The server contains any known vulnerabilities

If the server is running an obsolete version, the risk of exploitation increases significantly.

● Web Server Configuration Check

Nikto identifies potential misconfigurations such as:
– Enabled directory listing
– Dangerous HTTP methods (PUT, DELETE, OPTIONS)
– Missing security headers (X-Frame-Options, X-Content-Type-Options, CSP, etc.)

These issues can lead to attacks such as enumeration, unauthorized file uploads, or information disclosure.

● Sensitive Files and Directories Detection

Nikto automatically scans for:
– Common administrative or test paths such as **/admin**, **/phpinfo.php**, **/test**, **/backup**, **/old**
– Backup files with extensions such as **.zip**, **.old**, **.bak**

If discovered, attackers may exploit these items to access internal information about the system.

● CGI-related Security Vulnerabilities

This includes:
– Outdated or vulnerable CGI scripts
– Files that allow arbitrary code execution
– Remote Code Execution (RCE) vulnerabilities

● TLS/SSL Assessment (for HTTPS-enabled servers)

Nikto checks for:
– Deprecated SSL protocols (SSLv2/SSLv3)
– Weak or insecure cipher suites
– Untrusted or misconfigured certificates

4.2. Classification of Vulnerability Severity (Grading the Vulnerability Level)

Based on real-world impact and the inherent severity of each issue, vulnerabilities can be categorized as follows:

● High Risk

Vulnerabilities in this category can typically be exploited directly to gain unauthorized control over the system. These include:
– Outdated or vulnerable CGI scripts capable of arbitrary code execution
– Severely outdated server versions associated with critical CVEs
– Directory listing enabled across the entire web server
– Dangerous HTTP methods (PUT/DELETE) exposed publicly

● Medium Risk

These issues often aid attackers in gathering information or preparing for subsequent exploitation:
– Exposure of configuration files or backup files
– Presence of **phpinfo()**, revealing internal server details
– Missing security headers
– Default configurations that have not been hardened

● Low Risk

Although not immediately dangerous, these weaknesses should still be remediated to enhance overall security posture:
– Disclosure of server version information
– Unsafe or poorly configured redirects
– Cookies lacking **Secure** or **HttpOnly** attributes

4.3. General Assessment of Nikto Findings

Based on the collected results, several observations can be made:

Nikto identified multiple findings related to server information disclosure, indicating that the system does not adequately conceal its fingerprint. This increases the likelihood that an attacker can analyze the environment and select appropriate exploits.

The presence of sensitive paths or backup files suggests improper or insecure configuration practices, which raises the risk of unintended information leakage.

Several essential security headers are missing, reducing the system's resilience against attacks such as clickjacking, MIME sniffing, or injection-based exploits.

If the server is operating on an outdated version, immediate updates are required to mitigate the severe CVEs highlighted by Nikto.

4.4. Conclusion

The Nikto scan results indicate that the web server configuration still contains several areas that require improvement. Although most findings fall within the medium and low-severity categories, they nonetheless provide attackers with opportunities to gather information or escalate their attacks when multiple vulnerabilities are chained together.

To enhance the overall security posture, the following actions are recommended:
– Update the server and framework to the latest stable versions.
– Disable directory listing.
– Remove unnecessary test or backup files.
– Implement all essential HTTP security headers.
– Restrict or disable dangerous HTTP methods.